

Terna Engineering College

Computer Engineering Department

Class: TE

Sem.: VI

Course: System Security Lab

PART A

(PART A : TO BE REFFERED BY STUDENTS)

Experiment No.14

A.1 Aim: Perform SQL injection on a vulnerable website.

A.2 Prerequisite:

1. Basic Knowledge of SQL queries, html/PHP.

A.3 Outcome:

After successful completion of this experiment students will be able to

To be able to set up firewalls and intrusion detection systems using open source technologies and to explore email security and explore various attacks like buffer-overflow, SQL injection and web-application attacks

A.4 Theory:

SQL Injection (SQLi) is a type of an injection attack that makes it possible to execute malicious SQL statements. These statements control a database server behind a web application. Attackers can use SQL Injection vulnerabilities to bypass application security measures. They can go around authentication and authorization of a web page or web application and retrieve the content of the entire SQL database. They can also use SQL Injection to add, modify, and delete records in the database.

An SQL Injection vulnerability may affect any website or web application that uses an SQL database such as MySQL, Oracle, SQL Server, or others. Criminals may use it to gain unauthorized access to your sensitive data: customer information, personal data, trade secrets, intellectual property, and more. SQL Injection attacks are one of the oldest, most prevalent, and most dangerous web application vulnerabilities.

To make an SQL Injection attack, an attacker must first find vulnerable user inputs within the web page or web application. A web page or web application that has an SQL Injection vulnerability uses such user input directly in an SQL query. The attacker can create input content. Such content is often called a malicious payload and is the key part of the attack. After the attacker sends this content, malicious SQL commands are executed in the database.

SQL is a query language that was designed to manage data stored in relational databases. You can use it to access, modify, and delete data. Many web applications and websites store all the data in SQL databases. In some cases, you can also use SQL commands to run operating system commands. Therefore, a successful SQL Injection attack can have very serious consequences.

- Attackers can use SQL Injections to find the credentials of other users in the database. They can then impersonate these users. The impersonated user may be a database administrator with all database privileges.
- SQL lets you select and output data from the database. An SQL Injection vulnerability could allow the attacker to gain complete access to all data in a database server.
- SQL also lets you alter data in a database and add new data. For example, in a financial application, an attacker could use SQL Injection to alter balances, void transactions, or transfer money to their account.
- You can use SQL to delete records from a database, even drop tables. Even if the administrator makes database backups, deletion of data could affect application availability until the database is restored. Also, backups may not cover the most recent data.
- In some database servers, you can access the operating system using the database server. This may be intentional or accidental. In such case, an attacker could use an SQL Injection as the initial vector and then attack the internal network behind a firewall.

PART B

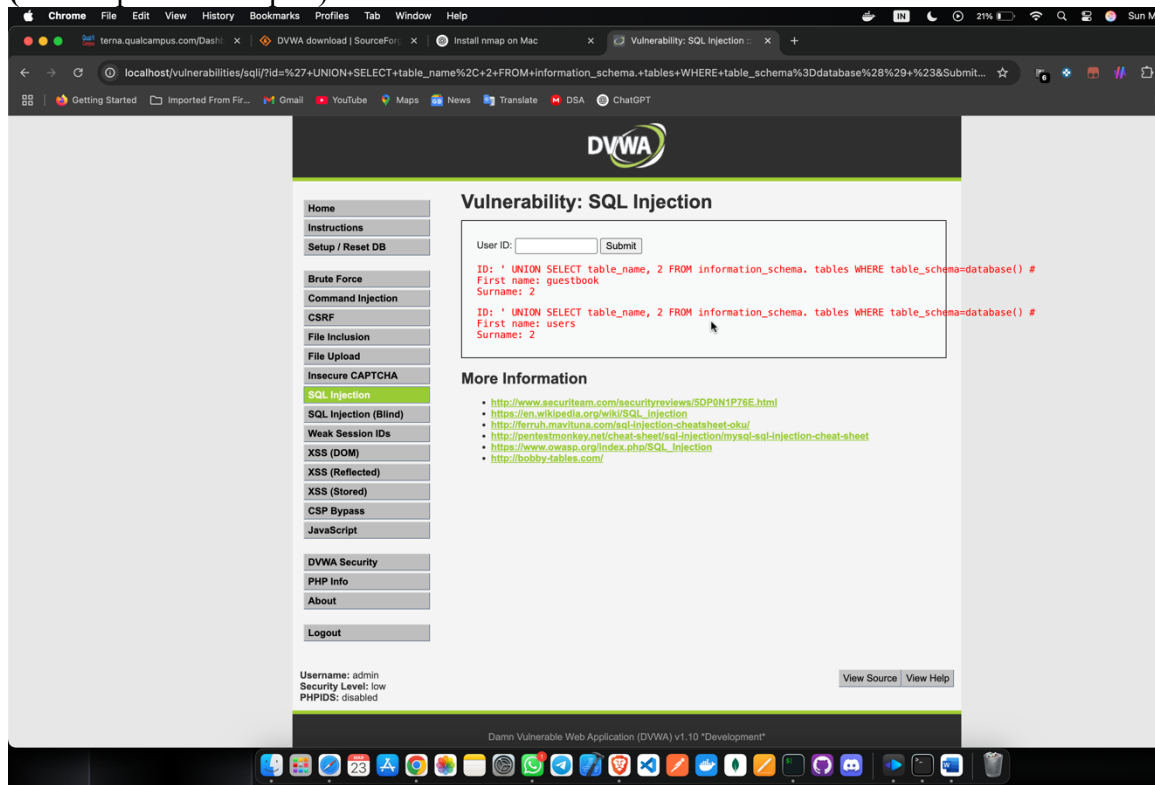
(PART B : TO BE COMPLETED BY STUDENTS)

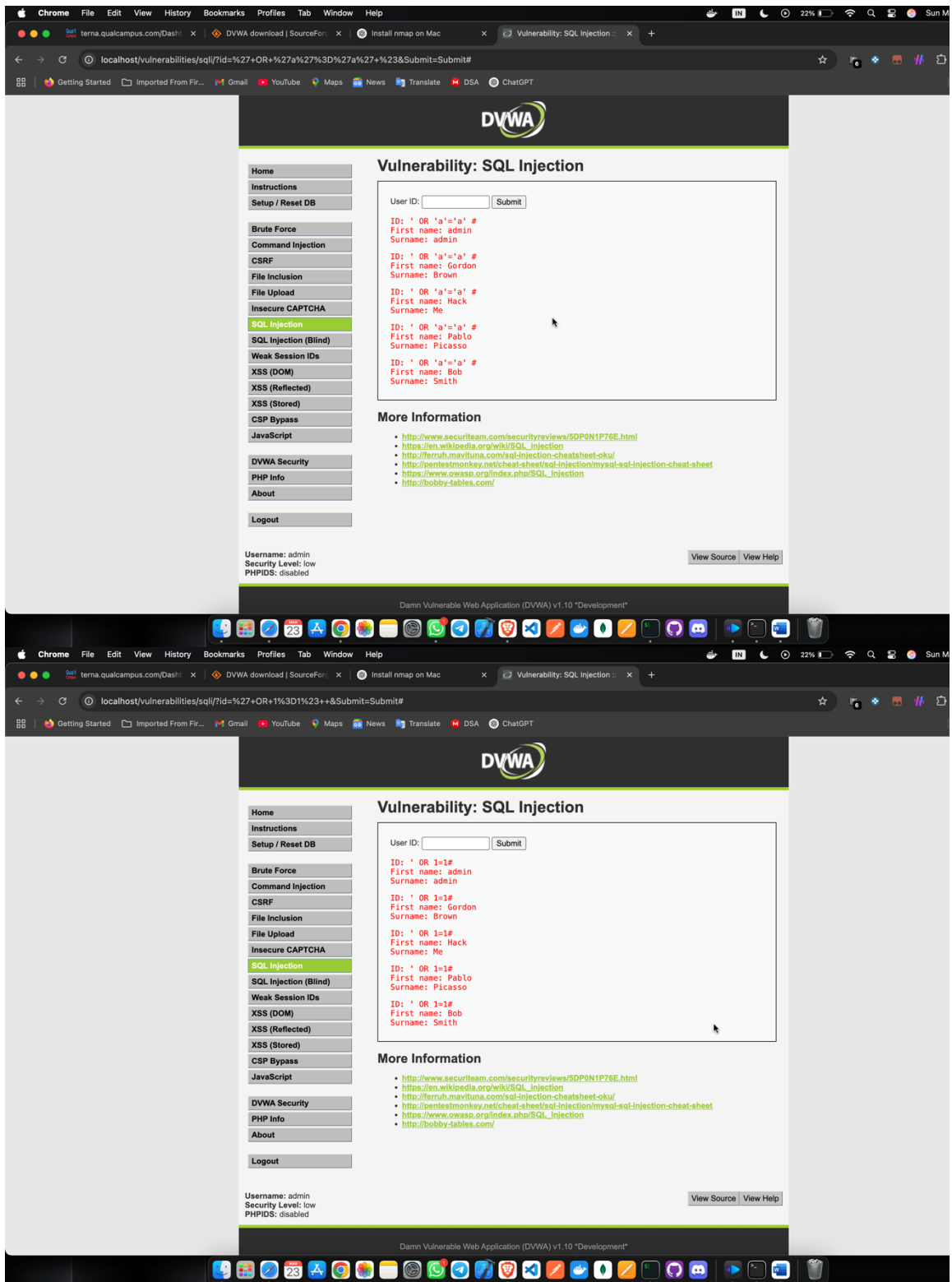
(Students must submit the soft copy as per following segments within two hours of the practical. The soft copy must be uploaded on the Blackboard or emailed to the concerned lab in charge faculties at the end of the practical in case there is no Black board access available)

Roll No.C54	Name: Quazi Md Moinuddin
Class :TE-C	Batch :C3
Date of Experiment: 4-3-25	Date of Submission:23-4-25
Grade :	

B.1 Output

(add snapshot of output)





B.2 Commands / tools used with syntax:

- 'OR' 1='1
'UNION SELECT user, password from user #

'UNION SELECT database(), 2 #

'UNION SELECT user(), 2 #

'UNION SELECT table_name, 2 FROM information_schema().tables WHERE
table_name=database() #

B3. Question of Curiosity:

CSS Expt -8

C-54

Q1 what is SQL injection?

→ SQL Injection is a web security vulnerability that allows an attacker to manipulate SQL queries executed by a web application by injecting malicious SQL code into input fields, an attacker can bypass authentication, access sensitive code, data, modify database records or even execute administrative operation on the database.

Q2 What is the query that makes SQL injection possible?

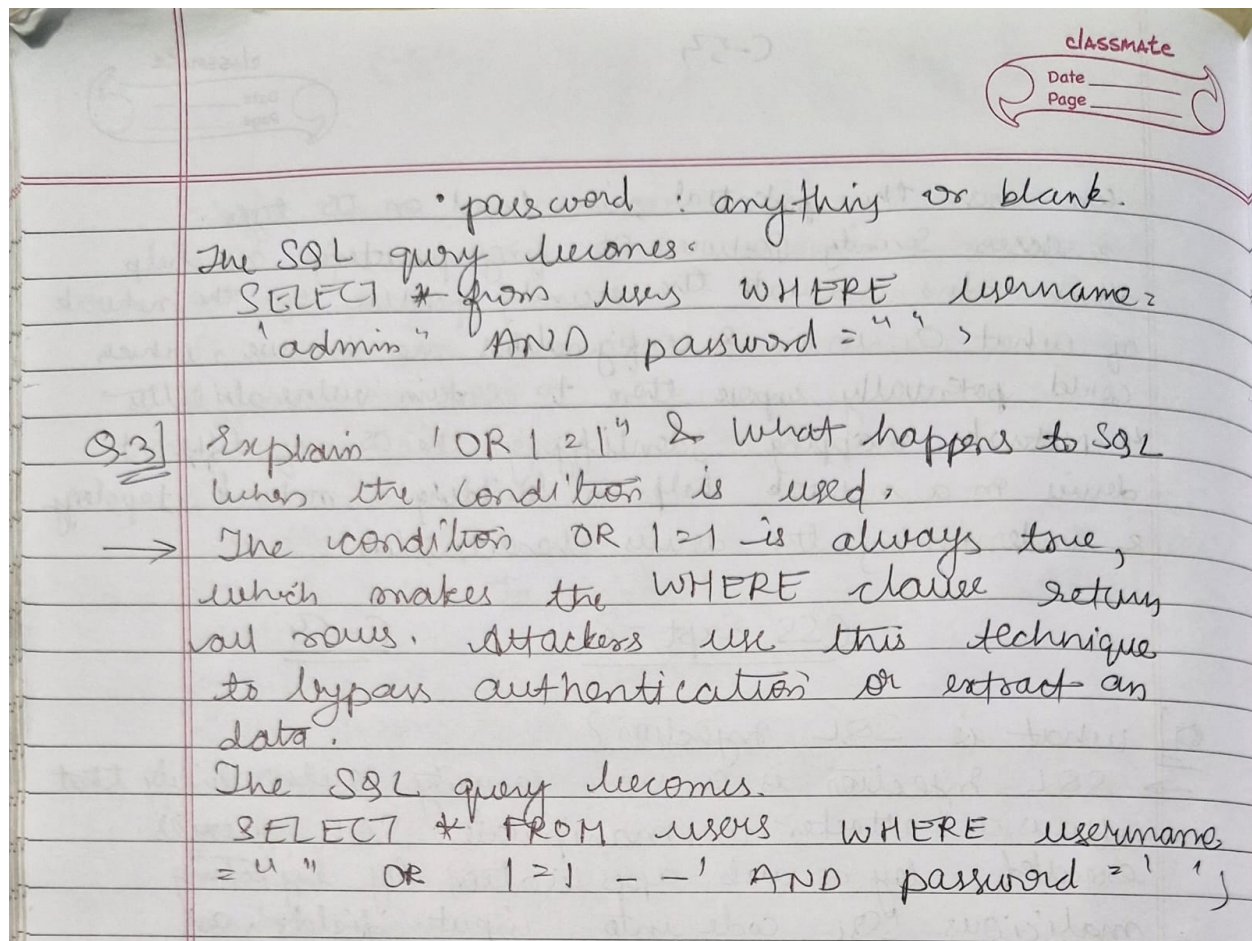
→ SQL injection is possible when an application dynamically constructs SQL queries using unsanitized user input.

for eg. Consider a login query:

SELECT * FROM users WHERE username = 'admin'
AND password = 'password'

If the application does not properly validate input, an attacker can input:

• Username: admin' - -



B.4 Conclusion:

(Write appropriate conclusion.)

In this practical, we successfully performed SQL injection on the Damn Vulnerable Web Application (DVWA), demonstrating how attackers can exploit poorly secured web applications to retrieve sensitive data. By injecting malicious SQL queries, we were able to bypass authentication, extract database information, and understand the risks associated with insecure input handling.